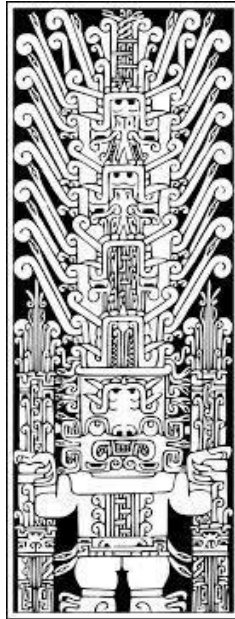


**UNIVERSIDAD NACIONAL FEDERICO
VILLARREAL**

**FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS**



TÍTULO:

**INFORME DE CLASIFICACIÓN DE ACTIVOS, GESTIÓN DE RIESGOS Y
CRITERIOS DE SEGURIDAD EN LAS EMPRESAS**

PRESENTADO POR:

Paredes Villanueva Erwin Crosby

DOCENTE:

VILLAFUERTE BARRETO, HERNAN OSWALDO

ASIGNATURA CIBERSEGURIDAD

LIMA - PERÚ

2026

Clasificación de Activos, Gestión de Riesgos y Criterios de Seguridad en las Empresas

1. Introducción

En el entorno empresarial actual, la información se ha convertido en uno de los activos más valiosos de cualquier organización, comparable en importancia a los recursos financieros o humanos. La creciente dependencia de sistemas digitales, redes interconectadas y almacenamiento en la nube ha ampliado la superficie de exposición ante amenazas cibernéticas, lo que obliga a las empresas a adoptar procesos formales de identificación, clasificación y protección de sus activos.

El presente informe desarrolla los conceptos fundamentales de clasificación de activos de información y gestión de riesgos de seguridad, así como los criterios que las organizaciones aplican habitualmente para priorizar la protección de sus recursos críticos. Se toma como referencia el marco normativo internacional ISO/IEC 27001 e ISO/IEC 27005, complementado con buenas prácticas de otros estándares reconocidos como NIST CSF y MAGERIT.

2. Objetivos

2.1 Objetivo general

Analizar los fundamentos, criterios y metodologías empleados por las empresas para clasificar sus activos de información y gestionar los riesgos asociados a la seguridad de dichos activos.

2.2 Objetivos específicos

- Definir los conceptos de activo de información, clasificación y riesgo dentro del contexto de la seguridad de la información.
- Describir los criterios y niveles utilizados para clasificar activos según su confidencialidad, integridad y disponibilidad.
- Explicar el proceso de gestión de riesgos: identificación, análisis, evaluación, tratamiento y monitoreo.
- Presentar ejemplos prácticos de inventario de activos y matrices de riesgo aplicables en un entorno empresarial.

3. Marco teórico

3.1 Seguridad de la información y activos

Un activo de información es cualquier elemento que tiene valor para la organización y que, por lo tanto, requiere protección. Puede tratarse de información propiamente dicha (bases de datos, documentos, contratos), de recursos tecnológicos (servidores, aplicaciones, redes), de personas (conocimiento y competencias del personal) o de elementos intangibles (reputación, imagen de marca).

La seguridad de la información se sustenta en tres propiedades fundamentales, conocidas como la tríada CID: confidencialidad, integridad y disponibilidad. La confidencialidad garantiza que la información solo sea accesible a

quienes están autorizados; la integridad asegura que los datos no sean alterados de forma indebida; y la disponibilidad garantiza el acceso oportuno a la información cuando se necesita.

3.2 Normas y metodologías de referencia

- ISO/IEC 27001: norma internacional que establece los requisitos para implementar un Sistema de Gestión de Seguridad de la Información (SGSI), incluyendo el inventario y clasificación de activos.
- ISO/IEC 27005: proporciona directrices específicas para la gestión de riesgos de seguridad de la información, complementando a la norma 27001.
- NIST Cybersecurity Framework (CSF): marco de referencia estadounidense estructurado en las funciones Identificar, Proteger, Detectar, Responder y Recuperar.
- MAGERIT: metodología de análisis y gestión de riesgos de los sistemas de información, de origen español, ampliamente usada en el sector público.

4. Clasificación de activos de información

4.1 Concepto e importancia

Clasificar los activos consiste en asignarles un nivel de sensibilidad y valor en función del impacto que tendría su pérdida, alteración o divulgación no autorizada. Este proceso permite priorizar los esfuerzos de protección, optimizar recursos y cumplir con requisitos legales y regulatorios (como normativas de protección de datos personales).

4.2 Tipos de activos

- Información: bases de datos, documentos, políticas, registros contables.
- Software: sistemas operativos, aplicaciones, código fuente.
- Hardware: servidores, equipos de cómputo, dispositivos de red.
- Servicios: conectividad, energía eléctrica, servicios en la nube.
- Personas: colaboradores con conocimiento crítico del negocio.
- Intangibles: reputación, imagen de marca, propiedad intelectual.

4.3 Criterios de clasificación

Los criterios más utilizados por las empresas para clasificar sus activos se basan en la tríada CID, evaluando para cada activo el nivel de impacto (bajo, medio o alto) que tendría una afectación en su confidencialidad, integridad o disponibilidad. A partir de esta evaluación se asigna un nivel de clasificación general, como se muestra en la siguiente tabla.

Nivel	Etiqueta	Criterio / Ejemplo
1	Público	Divulgación sin restricción; su exposición no genera daño (folletos, sitio web corporativo).
2	Interno	Uso exclusivo del personal; su divulgación causa un impacto reputacional bajo (procedimientos internos, directorios).

Nivel	Etiqueta	Criterio / Ejemplo
3	Confidencial	Acceso restringido a roles autorizados; su pérdida genera impacto financiero o legal moderado (datos de clientes, contratos).
4	Restringido / Crítico	Máximo nivel de protección; su compromiso pone en riesgo la continuidad del negocio (credenciales maestras, propiedad intelectual, datos financieros estratégicos).

4.4 Ejemplo de inventario de activos clasificados

Todo proceso de clasificación debe apoyarse en un inventario de activos actualizado, donde se identifique el propietario responsable, el tipo de activo y su nivel de clasificación, tal como se ejemplifica a continuación.

Tipo de activo	Activo	Propietario	Clasificación	Valor CID (C-I-D)
Información	Base de datos de clientes	Área Comercial	Confidencial	Alto - Alto - Medio
Hardware	Servidor de producción	Área de TI	Restringido	Medio - Alto - Alto
Software	Sistema ERP	Área de TI	Confidencial	Alto - Alto - Alto
Personas	Administrador de red	Gerencia de TI	Interno	Medio - Medio - Medio
Intangible	Reputación / marca	Alta Dirección	Confidencial	Alto - N/A - N/A

5. Gestión de riesgos

5.1 Concepto de riesgo

El riesgo se define como la posibilidad de que una amenaza explote una vulnerabilidad de un activo, generando un impacto negativo sobre la organización. Se expresa habitualmente como una función de la probabilidad de ocurrencia y el impacto potencial de un evento.

5.2 Proceso de gestión de riesgos

- Identificación de riesgos: reconocer amenazas, vulnerabilidades y activos afectados.
- Análisis de riesgos: estimar la probabilidad y el impacto de cada riesgo identificado, mediante métodos cualitativos, cuantitativos o mixtos.
- Evaluación de riesgos: comparar el nivel de riesgo calculado contra los criterios de aceptación definidos por la organización.
- Tratamiento de riesgos: seleccionar e implementar controles para mitigar, transferir, evitar o aceptar el riesgo.
- Monitoreo y revisión: dar seguimiento continuo a los riesgos y a la efectividad de los controles aplicados.

5.3 Matriz de riesgo (probabilidad x impacto)

Una herramienta habitual para priorizar riesgos es la matriz de probabilidad e impacto, que permite visualizar de forma sencilla qué riesgos requieren atención inmediata.

Probabilidad \ Impacto	Bajo	Medio	Alto	Crítico
Alta	Medio	Alto	Crítico	Crítico
Media	Bajo	Medio	Alto	Crítico
Baja	Bajo	Bajo	Medio	Alto

5.4 Estrategias de tratamiento del riesgo

- Mitigar: implementar controles técnicos u organizativos que reduzcan la probabilidad o el impacto (cifrado, copias de respaldo, control de accesos).
- Transferir: trasladar el riesgo a un tercero, por ejemplo mediante contratos de seguro o externalización de servicios.
- Evitar: eliminar la actividad o el proceso que genera el riesgo.
- Aceptar: asumir el riesgo cuando su nivel se encuentra dentro del umbral tolerable definido por la organización.

6. Criterios aplicados en las empresas

Más allá del marco normativo, cada organización adapta sus criterios de clasificación y gestión de riesgos según factores propios de su contexto:

- Sector de actividad y marco regulatorio aplicable (financiero, salud, gobierno, entre otros).
- Tamaño de la organización y madurez de su gobierno de seguridad de la información.
- Apetito y tolerancia al riesgo definidos por la alta dirección.
- Valor estratégico y económico de cada activo para el negocio.
- Requisitos contractuales con clientes, proveedores y socios.

Entre las buenas prácticas más comunes destacan: mantener el inventario de activos actualizado y con un propietario asignado, revisar periódicamente la clasificación de los activos, capacitar al personal en el manejo de información sensible, y realizar evaluaciones de riesgo de forma recurrente (al menos una vez al año o ante cambios significativos en la infraestructura).

7. Conclusiones

- La clasificación de activos es la base sobre la cual se construye cualquier estrategia de seguridad de la información, ya que permite identificar qué se debe proteger y con qué nivel de prioridad.
- La gestión de riesgos es un proceso continuo, no un evento puntual, y debe integrarse a la cultura organizacional para ser efectiva.

- La adopción de marcos reconocidos como ISO/IEC 27001 e ISO/IEC 27005 facilita la estandarización y comparabilidad de las prácticas de seguridad entre organizaciones.
- Los criterios de clasificación y tratamiento del riesgo deben adaptarse siempre al contexto, sector y apetito de riesgo particular de cada empresa.